

C&S Wholesale Grocers, Inc. and Subsidiaries

Policy Title: Technical Vulnerability Management
Status: Active
Policy Owner: IS Security and Compliance
Original Issue Date: 07/23/2020

SOP# CSISSEC004
Version: 1.0
Department: IT
Last Review: 11/24/2025

Document History

Document Revision	Reviewer	Description of Changes	Date
1	Diptanil Paul	Annual Review	07/30/2022
2	Sarah Ward	Document History table added Table of Contents added Added Workflow to Appendix	3/23/2023
3	Diptanil Paul	Annual Review	08/01/2023
4	Diptanil Paul	Annual Review	09/25/2024
5	Diptanil Paul	Annual Review	11/24/2025

C&S Wholesale Grocers, Inc. and Subsidiaries

Table of Contents

Document History..... 1

1. Purpose 3

2. Management Responsibilities..... 3

3. Technical Vulnerability Management Policy..... 3

 3.1. Business Need for Patch Management..... 3

 3.2. Technical Vulnerability Assessment 3

 3.3. Vulnerability Remediation Requests 3

 3.4. Vulnerability Remediation 3

 3.5. Application Maintenance Windows 4

 3.6. Simplex Changes..... 4

 3.7. Exceptions and Risk Acceptance 4

 3.8. Risk Acceptance Documentation 4

4. Roles and Responsibilities..... 4

5. Definitions 4

6. Related Documents..... 5

C&S Wholesale Grocers, Inc. and Subsidiaries

1. Purpose

To ensure technical vulnerabilities discovered on Company information systems are proactively remediated with the appropriate security updates.

2. Management Responsibilities

It is the manager's responsibility to ensure that his/her direct-report employees, interns, contractors, and/or third-party workers are aware of, and agree to abide by, the Company's requirements for Patch Management and that remediation of technical vulnerabilities are handled in accordance with the requirements of this policy.

3. Technical Vulnerability Management Policy

3.1. Business Need for Patch Management

A compromised computer threatens all computers and data on the Company network. To protect the integrity of Company operations it is essential that effective precautions are taken by the Company to protect itself against this threat, including the routine assessment and remediation of technical vulnerabilities.

3.2. Technical Vulnerability Assessment

In addition to the regular application of vendor-supplied software updates by IS Solver Group teams, the Information Security team shall conduct periodic vulnerability assessments to routinely assess Company systems for technical vulnerabilities in a manner that is not impactful to Company operations and consistent with the Company's Threat and Risk Assessment policy. The purpose of the assessments is to identify existing vulnerabilities in systems that could be exploited by an attacker. These could include known software vulnerabilities that have not been patched, configuration errors that need to be corrected or inadequate security practices that need to be addressed.

3.3. Vulnerability Remediation Requests

When vulnerabilities are discovered on Company systems, a ticket shall be created by the IS Security team and placed in the appropriate Solver Group Team's queue with all of the necessary information to remediate the issue, including the severity of the vulnerability.

3.4. Vulnerability Remediation

The scheduling of the installation of updates will depend upon a number of factors including:

- The criticality of the systems being updated
- The availability of maintenance windows
- The expected time taken to install the updates (and requirements for service outages to users)
- The degree of risk associated with any vulnerabilities that are closed by the updates

Vulnerabilities should be patched according to the timelines in the table below and in accordance with Company Production Change Management policies.

Severity	Description	Remediation Timeline
Emergency/ZeroDay	A vulnerability which poses a significant risk to the organization which requires immediate emergency patching.	As soon as possible
Critical	Critical risk findings must be considered a high priority when assessing overall security posture and risk remediation. These vulnerabilities can be easily exploited and may negatively impact business operations and continuity.	45 Days
High	High risk findings should be reviewed and remediated within a short time frame. These vulnerabilities may allow access to organizational assets and data or be leveraged to create further issues within the security posture.	60 Days
Medium	Medium risk findings should be addressed after critical and high findings have been remediated. While these findings may allow exploitation of other vulnerabilities, they do not pose a substantial threat to business operations and continuity.	90 Days

C&S Wholesale Grocers, Inc. and Subsidiaries

Severity	Description	Remediation Timeline
Low	Low risk findings are informational and do not pose a significant risk to business operations and continuity. These vulnerabilities should be considered for remediation on a case-by-case basis.	N/A

3.5. Application Maintenance Windows

IS Leadership shall coordinate with the appropriate solver groups and business partners to establish periodic maintenance windows to allow for the routine application of patches. The maintenance windows shall be documented, including any adjustments to the remediation timelines.

3.6. Simplex Changes

For updates that are low risk and regular, a simplex change may be defined within the change management process to allow this to happen without excess administrative overhead. These simplex changes, with CAB approval, shall be documented.

3.7. Exceptions and Risk Acceptance

Exceptions to compliance with any part of this policy may pose a risk to the confidentiality, integrity, and availability of Company Information Systems and Data and may only be approved by the CIO. To request an exception, a risk acceptance request form must be completed by the Solver Group and is subject to the review and approvals below.

3.7.1. Risk Acceptance Approval Requirements

All Risk Acceptance request require:

- Solver Group Manager Approval
- Approval from Tower Head
- Information Security Review and Analysis
- CIO Approval

3.8. Risk Acceptance Documentation

All exceptions and any mitigating controls must be documented and reviewed periodically, at least annually

4. Roles and Responsibilities

Role	Responsibility
Manager of IS Security & Compliance	The Manager of IS Security & Compliance has responsibility for ensuring adherence by internal and external resources to policies and procedures instituted within the Information Services environment.
Solver Group Team (SGT)	The working level group of IS and Business personnel tasked to resolve a technical vulnerability.
Security Analyst/Engineer	The IS Security analyst or engineer having primary responsibility for identifying vulnerabilities on Company systems and providing the Solver Group Team the information needed in order to resolve the technical vulnerability.
Tower Management Team	A Tower Management Team consists of an IS Tower Lead plus any members of his or her higher echelon managerial staff designated to participate in the change management and technical vulnerability remediation process.
Chief Information Officer (CIO)	The CIO is the supreme authority for approving Risk Acceptance requests.

5. Definitions

Term	Definition
Technical Vulnerability	A technical vulnerability is an inherent weakness in an information system, security procedures, internal controls, or implementation that could be exploited by someone to gain unauthorized access to Company Information Systems or Confidential Information, disrupt the normal operation of business, or make some other kind of gain.
Compromised Computer	A computer that has been infected with Malware or under the control of an unauthorized party.

C&S Wholesale Grocers, Inc. and Subsidiaries

Term	Definition
Malware	Malware is any code or software that may be harmful or destructive to the information processing capabilities of the Company and is one of the primary tools used by attackers to circumvent security in order to make some kind of gain or to disrupt the normal operation of the business.

6. Related Documents

- CSISSD002 IS Threat-Risk Assessment
- CSISSEC005 - Application Maintenance Windows
- CSISSW002-03 - Simplex Change Standard

7. Appendix – Vulnerability Management Workflow

